

Assessor Marking Scheme for Cyber Essentials Danzell Question Set

FOR USE BY LICENSED IASME CERTIFICATION BODIES ONLY

Version 9.1
June 2026

© The IASME Consortium Ltd 2026 All rights reserved.

The copyright in this document is vested in The IASME Consortium Ltd. The document must not be reproduced, by any means, in whole or in part or used for manufacturing purposes, except with the prior written permission of The IASME Consortium Ltd and then only on condition that this notice is included in any such reproduction.

Information contained in this document is believed to be accurate at the time of publication but no liability whatsoever can be accepted by any member of The IASME Consortium Ltd arising out of any use made of this information.

Version History

Version	Date	Description
3.0	April 2018	Updated for new question set
3.1	May 2018	Typo corrections, clarity on marking scope and additional GDPR guidance
4.0	January 2019	Updated for new question set v11
4.1	January 2019	Corrected typos
4.2	March 2020	Updated to improve clarity and relevance of guidance
4.2a	April 2020	Typos corrected
4.3	November 2020	Marking Scheme EOL Document Added
4.4	January 2021	Updated guidance for A6.1, updates to EOL document including the addition of Chromebook details
4.5	February 2021	Amendment to Android bullet point wording
4.6	February 2021	Updated EOL information, including the addition of Linux Debian & RedHat details
5.0	April 2021	Updated for new question set version Beacon
5.1	May 2021	Re-formatting of tables
5.2	May 2021	Updated EOL Information
5.3	June 2021	Updated EOL Information
5.4	August 2021	Updated Contents
6.0	December 2021	Evendine question set
6.1	January 2022	Typos corrected
6.2	January 2022	Amended guidance for A6.4.2 and A6.5.2 to remove link to respective previous questions.
6.3	February 2022	Update to A2.5 to match to question set.
6.4	February 2022	Typo corrected to A7.17 guidance
6.5	April 2022	A1.5 – Now Multi-choice to reflect change in Pervade. A2.4 and A2.5 – Advisory notice on firmware updated. A2.6 – Updated iOS support definition. A3.4 and A3.5 – Removed, A3.6 is now A3.4. A5.11 – Removed brute force marking requirements. A6.5.1 – Updated wording to guidance due to typo. A7.15 – Advisory added for scenario where MFA is available at additional cost only.
6.6	May 2022	A2.7 – Assessor guidance changed to amend reference to incorrect homeworker question number.
6.7	October 2022	Section 2 – Assessor notes updated in all questions to give clarity surrounding required action for pool assessments where the scope is unclear.

		A4.5 – Clarification that an answer of ‘Yes’ should be marked as compliant. A7.16 – Change to marking for administrator accounts where cloud services do not make MFA available.
7.0	November 2022	Draft Marking guide created for Montpellier question set.
7.1	January 2023	Approved Master Marking Guide aligned to the Montpellier Question Set. Additional Question A1.8.1 has been added.
7.2	January 2024	Update to guidance in A7.16 and A7.17 Update mark to be awarded on A1.8 and A1.8.1 Correction in A1.9
7.3	July 2024	Question A1.10 (two part question) added with marking as information only. Clarification about using ‘More Information Required’ in Pool assessments.
8.0	August 2024	Updated for the 2025 Willow Question Set
8.1	January 2025	Changes to questions reflected in marking guide A7.4 Guidance added to A2.4 and A6.1
8.2	April 2025	Amended question A4.7
9.0	April 2026	Updated for the 2026 Danzell Question Set
9.1	June 2026	A4.7 yes/no typo corrected

Contents

Version History.....	1
Overview.....	4
Assumptions.....	4
The Cyber Essentials Scheme.....	4
Certification Dates.....	4
What is a suitable answer?.....	5
Role of the Assessor.....	7
Assessing Scope.....	8
Question Numbering.....	8
The Marking Scheme.....	9
Unanswered Questions.....	9
Compensating Controls.....	10
Central Pool marking guidance.....	10
Cloud Services – Shared Responsibility Model.....	11
Guidance on AI answers.....	11
General Scoping Guidance.....	11
Higher Bar for Cyber Essentials Plus.....	12
Danzell question set marking guidance.....	12

Overview

This document provides guidance to licensed assessors for assessing the Cyber Essentials information security standards. Its aim is to encourage consistency by providing clarity. The IASME moderators will provide an ultimate decision if the guidance provided within this document does not resolve a particular query.

Assumptions

This document is not intended to teach information security. Assessors are expected to have relevant experience in information security and suitable industry-recognised qualifications before undertaking assessments.

As an assessor, you will be required to use your expertise and experience to evaluate a client's answers to the best of your ability.

The Cyber Essentials Scheme

Cyber Essentials is a government-backed, industry supported scheme to help organisations protect themselves against common cyber-attacks. It covers five key technical controls that organisations should have in place to provide a basic level of cyber security.

IASME is the National Cyber Security Centre (NCSC) partner for delivering the Cyber Essentials scheme.

Certification Dates

Certificates are valid for one year from the date of certification. The certification is based on a 'point in time' assessment, which refers to the date the certificate is issued. It is the organisation's responsibility to maintain compliance with the Cyber Essentials controls throughout the certification period. The certification date is defined as the date the assessor approves the assessment, not the date it was submitted. Additionally, all systems must be supported as of the certification date.

What is a suitable answer?

At the verified self-assessed level, Cyber Essentials breaks down the complexities of compliance into a large set of simple questions. Each question asks about a very specific piece of the security jigsaw and implicit in the question is the correct answer. In other words, for the vast majority of the questions the correct answer is a positive one. Questions are split into two categories, based on the type of answer the applicant is expected to provide. Either:

1. a simple yes/no answer or selection from a list of choices,
or
2. a detailed answer consisting of a couple of sentences of notes

The two question types are discussed below.

1. Questions requiring a YES/NO answer

The questions are simply marked based on the selection of either yes or no by the applicant. If the answer agrees with the question (and in most cases an answer of “yes” is compliant), then the answer should be marked as compliant.

2. Questions requiring notes

Candidates are expected to supply a couple of sentences of supporting notes for these questions. The purpose of these notes is to provide the assessor with reassurance by:

- confirming that the candidate *understands the question*
- confirming that a broadly appropriate system or control is in place

The notes are not expected to provide detailed evidence of compliance. IASME does not allow candidates to upload supporting evidence, except asset information, because we do not expect assessors to review the low-level details of systems to assess compliance. This step is part of the audited assessment (Cyber Essentials Plus) not the self-assessment.

If any questions are unanswered, left blank, or answered ‘not applicable’ or ‘N/A’, the assessor must mark the assessment as a failure overall and provide an explanation to the applicant in assessor notes.

Examples of acceptable answers:

Question	Answer	Comments
A4.2.1: Please describe the process for changing your firewall password.	When we receive a new router, we login to the admin panel via the web browser and change the default password in line with our password policy.	The applicant clearly understands the question and provides confidence that the password has been changed on the only firewall.
A6.4.2: Where auto updates are not being used, how do you ensure all high-risk or critical security updates and vulnerability fixes of all operating systems and firmware on firewalls and routers are applied within 14 days of release?	Auto updates are applied to all OS and the majority of our software applications. The IT Team check for firmware updates each week and download any security updates and install remotely on a Friday afternoon.	The applicant understands the question and states that all OS updates automatically and have a clear process in place to capture and install firmware updates in a compliant timeline.
A7.7: How does your organisation prevent administrator accounts from being used to carry out everyday tasks like browsing the web or accessing email?	All administrators are required to go through annual training and sign off the ICT acceptable use policy. In the policy it highlights that they must use separate admin accounts and these should not be used for everyday tasks like web browsing or emails.	The applicant understands the question and has provided details of a clear process.

Examples of unacceptable answers:

Question	Answer	Comments
A4.2.1: Please describe the process for changing your firewall password.	Yes – we use MS 365 which has a built-in filter, I've changed the password to our Microsoft account.	The applicant doesn't understand the question – Office365 is a cloud service and is not a hardware firewall.
A6.4.2: Where auto updates are not being used, how do you ensure all high-risk or critical security updates and vulnerability fixes of all operating systems and firmware on firewalls and routers are applied within 14 days of release?	Yes – we manually check for all security updates. Any critical security updates are patched within 48 hours.	The applicant has not included high-risk security updates within their answer.
A7.7: How does your organisation prevent administrator accounts from being used to carry out everyday tasks like browsing the web or accessing email?	We don't have anyone with admin access. All admin tasks are carried out by our MSP.	When an applicant gives admin accounts out to a third party to manage their systems, they are still required to demonstrate how they ensure the controls are applied over their infrastructure by the third party. This could be arranged through SLA or other contractual agreement, or the applicant could confirm how the third party manages admin use in a compliant manner.

Role of the Assessor

Sometimes, an answer to one question may conflict with the answer to another, which could indicate a misunderstanding, a lack of clarity, or potentially dishonest responses. It is not the assessor's role to investigate dishonesty. Assessors are expected to challenge answers that appear inconsistent, unclear, or misaligned with the standard. Assessors should use their knowledge and training to ensure that responses are technically correct and meet the requirements of the standard.

Assessing Scope

Assessors must agree on the scope of the assessment with the applicant before the assessment begins, ensuring that the scope boundary is clearly defined, including the business unit managing it and the network boundary.

When marking central pool assessments, you will need to use the 'more information required' option to clarify the scope.

For the avoidance of doubt, scope in Cyber Essentials refers to a network. It does not refer to a geographical location, a job role, or department. Boundaries of scope must be clearly defined, and any segregation must be done using a firewall or VLAN.

The assessor must check that, for example, the number of sites matches the number of network devices listed in the assessment. Obvious discrepancies in the number of IP addresses, routers, firewalls etc. must be challenged by the assessor.

It is the nature of a self-assessment that the answers given rely on the attestation of a board member of the candidate organisation to confirm they accurately reflect the company's situation. Greater assurance is given at the audited level of the standards.

However, if answers to questions contradict each other or are unclear, the assessor must record this in the assessor notes and request that the candidate update their submission in the Pervade portal. If marking within of the central pool of assessors, use the 'more information required' option and provide specific guidance in the notes. If the responses remain contradictory or fail to meet the standard after the update, the application must be marked as non-compliant.

Question Numbering

All questions that form part of the Cyber Essentials assessment begin with the letter A and then a number (for example **A.4.2**).

The Marking Scheme

The response to a Cyber Essentials question can be marked in one of four ways:

1. **Compliant** – meets the requirement for the control
2. **Non-compliance** – does not meet the requirement for the control
3. **Fail** – automatic fail of the assessment if any one of the following controls are absent:
 - Board level approval
 - Supported operating system
4. **More Information Required** – Not enough information has been provided, or the applicant has not understood the questions – does not fail the assessment

The allowances below are totals.

Certification	Non-compliances	Fail
Cyber Essentials	Two or fewer	None

Unanswered Questions

All the questions are important to the assessment, and all must be answered by the client. All unanswered questions without a note providing a valid reason should be marked as a **fail overall**.

Compensating Controls

A compensating control is a set of policies and procedures that attempt to provide the same level of protection that correctly implementing the original requirement would offer. It should always be regarded as a second-best option to implementing the original requirement and introduces greater complexity to the assessment process. Compensating controls are unacceptable for Cyber Essentials because the standard requires the specific controls described to be implemented.

Central Pool marking guidance

When marking a Central Pool assessment the use of 'more information required' can be used as an alternative to awarding a non-compliance or an automatic failure. This option is not compulsory and can be used at the discretion of the assessor.

We would encourage all assessors to use this option, particularly around defining the scope of the assessment. If the client does not supply adequate information on the first 'more information required' request, then you are not obliged to go back and ask for the same information several times until you receive a satisfactory response. You can then mark as a non-compliance or automatic failure if you wish.

Please remember that using 'more information required' does not count as one of the two fails allowed.

Assessors please note: Please consider the applicant when using this option as it is the only way to confirm scope when marking a central pool assessment.

When marking central pool assessments do not change answers that were previously marked as compliant without first coming to IASME who will provide guidance to the applicant.

Cloud Services – Shared Responsibility Model

When marking the assessment, you can refer to the table given below to determine what the applicant should be including within their assessment for their cloud services.

Requirement	IaaS	PaaS	SaaS
Firewalls	Applicant/Cloud provider	Cloud provider and sometimes also the Applicant	Cloud provider
Secure Configuration	Applicant/Cloud provider	Applicant/Cloud provider	Applicant/Cloud provider
Security Update Management	Applicant/Cloud provider	Applicant/Cloud Provider	Cloud provider
User Access Control	Applicant	Applicant	Applicant
Malware Protection	Applicant/Cloud provider	Cloud provider and sometimes also the Applicant	Cloud provider

Guidance on AI answers

AI is being applied to many areas of IT, and Cyber Essentials is no exception. If you as an assessor suspect that AI is being used to generate answers, check that that the answers are in context with the rest of the assessment, taking into account the size of the organisation and the systems being used. If you are unsure, please contact the IASME support team for further advice by raising a support ticket.

General Scoping Guidance

The following devices and services are often ignored or missed by applicants. When this is the case you as the assessor must challenge the applicant, so that they write a statement to confirm they do not have these devices or services.

- All end user devices including Bring Your Own Device (BYOD). Please note that a scope that does not include end-user devices is not acceptable
- Mobile devices including mobile phones, tablets, and smartphones
- Cloud services

You should never request specific details of individual firmware version numbers. This level of detail is not required for Cyber Essentials compliance. Your focus should be on confirming whether the device is still capable of receiving regular firmware updates.

Higher Bar for Cyber Essentials Plus

No non-compliances can be accepted if the applicant wishes to proceed to Cyber Essentials Plus.

Danzell question set marking guidance

The following table provides advice on how to mark each question in the Cyber Essentials question set. It confirms whether the question attracts a non-compliance or a fail of the whole assessment. When marking, the whole assessment must be taken in context. Do not mark questions in isolation – check where answers have an impact on other questions. For example, answers in Section 2 relate to A6.4.



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 1: Your Organisation				
A1.1	What is your organisation's name?	Notes	Fail if blank	The answer to this question will be entered on the certificate as the name of the certified company. Further guidance: Entities sharing a Cyber Essentials Certification
A1.2	What type of organisation are you?	Multiple choice	Fail if blank	This question is to provide statistics required by UK Government.
A1.3	How many employees are there in the organisation?	Notes	Fail if blank	This will be the number of people who are working for the organisation, including all legal entities. This would include any person carrying out work for the organisation. For example, volunteers or trustees at a charity or third-party contractors. This information is required to work out the correct charge for the certificate.
A1.4	What is your organisation's registration number?	Notes	Fail if blank	The registration number will be provided by bodies such as Companies House (UK), Charities Commission (UK), Companies Registration Office (Republic of Ireland). If applicable, only one registration number is required to represent an entire group. Not all companies will have a registration number. In this case, an applicant should still enter a note to state this.



A1.5	What is your organisation's registered address?	Notes	Fail if blank	The answer to this question will be entered on the certificate as the address of the certified company.
A1.5.1	Please provide the operational addresses, if different to your registered address.	Notes	Fail if blank	If the registered address is the same as the operational address, please enter 'same address'.

Certificates

Depending on the way the organisation is set up, one or more assessment accounts may be required. See the following guidance article to determine whether you will need a single assessment account or more than one.

Guidance:

[Entities sharing a Cyber Essentials Certification](#)

Entities or companies require different assessments in the following cases:

Different Legally Responsible Persons: If the entities do not share the same director or board-level member who can sign off on the assessment.

Different Network Infrastructure: If the entities do not share the same network infrastructure.

Separate Legal Entities: If the entities are separate companies with no shared governance or oversight.



A1.6	Do you have more than one legal entity, including subsidiaries, within the scope of this assessment?	Yes/No	Fail if blank	Guidance: Entities sharing a Cyber Essentials Certification
A1.6.1	Please provide the name, company number and registered address of any additional legal entities that are included.	Notes	Fail if blank	
A1.7	What is your main business?	Multiple choice	Fail if blank	This question is to provide statistics required by UK Government.
A1.8	What is your website address?	Notes	Fail if blank	Assessors should always look at the website to provide background into the size and nature of the business to put the assessment into context.
A1.9	Is this application a renewal of an existing certification or is it the first time you have applied for certification?	Select either "Renewal" or "First Time Application"	Fail if blank	This question is to provide statistics required by UK Government.



A1.10	What are the two main reasons for applying for certification?	Multiple Choice	Information only	This question is to provide statistics required by UK Government. Additional information is now required depending on which answer is given. The Pervade portal will provide an automatic notes field detailing what information is required.
A1.10.1	Who is the commercial contracting organisation?	Notes	Information only	This question is to provide statistics required by UK Government. Additional information is now required depending on which answer is given. The Pervade portal will provide an automatic notes field detailing what information is required.
A1.10.2	Who is the government contracting organisation and what is the contract number?	Notes	Information only	This question is to provide statistics required by UK Government.
A1.10.3	Who is the grant authority?	Notes	Information only	This question is to provide statistics required by UK Government.
A1.10.4	Who is the regulator?	Notes	Information only	This question is to provide statistics required by UK Government.
A1.10.5	What are the reasons you have applied for the certification which you described as "other"?	Notes	Information only	This question is to provide statistics required by UK Government.



A1.11	Have you read the ' Cyber Essentials Requirements for IT Infrastructure ' document?	Yes/No	Fail if blank	In order for an applicant to understand the requirements for CE they should ensure that they have read the NCSC's requirements document. Cyber Essentials Requirements for Infrastructure v3.3
A1.12	Have you spoken to an assured NCSC Cyber Advisor to help with your application? Find an assured Cyber Advisor	Yes/No	Information only	
A1.13	Can IASME and their expert partners contact you if you experience a cyber breach?	Yes/No	Information only	We would like feedback on how well the controls are protecting organisations. If you agree to this, we will provide you with a contact email (security@iasme.co.uk) and ask that you let us know if you do experience a cyber breach. IASME and expert partners will then contact you to find out a little more, but all information will be kept confidential.
A1.14	Where did you hear about Cyber Essentials?	Multiple Choice	Information only	This question is to provide statistics required by UK Government
A1.15	Can IASME contact you for research purposes?	Yes/No	Information only	
A1.16	Have you signed up to the NCSC's free Early Warning service?	Yes/No	Information only	Guidance: NCSC Early Warning



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 2: Scope of Assessment In this section, you need to explain which parts of your organisation's IT system you want to include in the Cyber Essentials certification. This is called the scope. The scope can cover either your entire organisation or just a specific part of it (for example, only the UK branch of a multinational company). If you're not including the whole organisation, this is called a "partial scope." In this case, you must clearly list any networks or systems that are excluded in section A2.2.1. This information will not be made public. You'll also need to provide details about all devices and services that are connected to the internet and access your organisation's data or services. This includes computers, laptops, thin clients, servers, mobile phones, tablets, firewalls/routers, and cloud services. For most devices, you only need to provide the make (brand) and operating system. However, for firewalls and routers, you must also include the model of the device (this is required for question A2.5). Development, testing, and penetration testing networks should not be included in the scope. These networks must be kept separate from the rest of your IT systems using a firewall or VLAN. It's important to note that you cannot exclude devices used by employees (such as laptops, desktops, or mobile phones) from the scope. Similarly, cloud services must always be included in the scope. Further guidance: Knowledge Hub - Scope Scope - FAQ				



A2.1	Is this assessment for your whole organisation or only a part of it?	Multiple choice	Fail if blank	The applicant can decide to scope the whole organisation or only part of it (partial scope). Guidance: About Scope Subset Scoping Guidance
A2.2	If you are certifying only part of your organisation, please write a detailed description of the scope here.	Notes	Fail if blank	If the scope is partial, any excluded sub-sets must have defined boundaries of ownership and management. A sub-set is defined by a firewall or VLAN boundary as outlined in the CE Requirements document. Network segregation must be done at layer 2 or 3 of the OSI model. Other methods such as security groups, microsegmentation or software-based methods are not compliant. The assessor needs to check that the information provided in the assessment shows that compliant segregation is in place. Further guidance: About Scope Subset Scoping Guidance The scope description must be described with reference to the networks listed in A2.4, so that it is clear to the reader of the certificate what networks are in scope. If only a small portion of the organisation's infrastructure has been included, it would be acceptable to see, for example, "Malvern production network only excluding all other networks". Scope descriptions should not include addresses, products or project names unless they are included in the name of the network.



				- The use of microsegmentation, Domain, Active Directory, User Accounts, Access Control Lists (ACLs) and other technical methods to define the boundaries of scope are not compliant. - Removing devices from scope by an individual firewall rule whilst it remains on a scoped network is not compliant. - All devices connected on a scoped network must be included in the assessment, exclusion by device type is not allowed. - If the scope is unclear or poorly defined, request that the client clarify the scope by updating this question. - If you are marking through the IASME central pool, see Central Pool marking guidance above. Reminder: Cloud services cannot be excluded from scope
A2.2.1	Please provide a description of any networks that have been excluded from the assessment by creating a sub-set.	Notes	Fail if blank	When partial scope has been selected in A2.1 a list of the networks that have been excluded must be provided here. This information will not be made public. Guidance: Subset Scoping Guidance The answer to this question should be used to determine that the assessment has been correctly scoped and that the excluded networks have been properly segregated.
A2.2.2	Where one or more sub-sets have been created, please describe how this has been achieved.	Notes	Fail if blank	The assessor needs to make sure that any sub-sets have been created in the proper manner and provide segregation via firewall or VLAN. The answer to this question should be used to determine that the assessment has been correctly scoped and that the excluded networks have been properly segregated.



A2.3	Are the networks included in the scope of this assessment being used at the company locations you provided earlier?	Notes	Fail if blank	The assessor must confirm whether all in-scope networks are being used at the company locations listed in Question A1.5.1. If the in-scope networks are being used at locations other than those listed in A1.5.1, the applicant must provide the number of additional sites where these networks are being used. Look to see that the description provided makes sense when combined with the answers to questions A2.4, A2.5 and A2.5.1. It is critical that the scope is clear. If the scope is unclear or confusing to you, request that the client clarify the scope by updating this question. If you are marking through the IASME central pool, you must use the option of 'more information required' and ensure that you add appropriate comments and complete marking the assessment.
A2.3.1	Do you have an internet connection for each site in your organisation?	Yes/No	Fail if blank	This question is about whether the applicant is using the public internet or whether they have some type of private connection.
A2.3.2	If no, please describe the way that your sites are connected.	Notes	Fail if blank	Assessors should check that the information given in A2.5 is consistent with the answer given here – for example, that there are sufficient network devices listed for the number of sites. Where an MPLS system is used, this will usually have an internet connection. Split tunnel VPN is not permitted.



A2.4	Please provide a list of networks that will be in scope for this assessment.	Notes	Fail if blank	You should expect to see a brief description of networks in scope (for example “Office LAN at head office”) to assist your understanding of the business. It is not necessary to include detailed information such as IP ranges or details of which ports are enabled. Home worker location details are not required. The answer to this question should be used to determine that the assessment has been correctly scoped and that the excluded networks have been properly segregated. It is critical that the scope is clear. If the scope is unclear or confusing to you, request that the client clarify the scope by updating this question. If you are marking through the IASME central pool, you must use the option of ‘more information required’ and ensure that you add appropriate comments and complete marking the assessment.
A2.4.1	How many staff are home or remote workers?	Notes	Fail if blank	Any employee that has been given permission to work remotely (for any period at the time of the assessment) needs to be classed as a home/remote worker for Cyber Essentials. For further guidance see the Home and Remote Working section in the Requirements document. Cyber Essentials: Requirements for IT Infrastructure v3.3



A2.4.2	How are home/remote workers connecting to your organisational data and services?	Notes	Fail if blank	For example, via home router, business-provided router or corporate VPN.
A2.5	Please provide a list of network equipment that will be in scope for this assessment (including firewalls and routers). You must include make, model and quantity of each device listed.	Notes	Fail if blank	You should expect to see a brief description of network equipment in scope, including quantity, make and model of each device (e.g. Fortinet Fortigate 100F) to assist your understanding of the business and to establish that equipment is in support. Do not include information such as IP ranges or details of which ports are enabled etc. If an unsupported firewall or router is listed then an auto-fail must be awarded. Where no boundary network equipment is listed you should request more information for clarification on where the firewall controls are being applied and what is acting as their boundary. For example - software firewall or virtual firewall. Make and model of boundary devices are required to determine compliance against vendor-published information. You as the assessor must be confident that the details supplied in the answer prove that the scoped devices are still fully supported by the vendor.



				Where there are no public end of life details published by the vendor you can confirm support by checking the latest release of firmware and using your knowledge as an assessor to make a decision in line with the trend of the firmware release cycle. You should never request specific details of individual firmware version numbers. Your focus should be on confirming whether the device is still capable of receiving regular firmware updates. If you are marking through the IASME central pool, see Central Pool marking guidance above. Quantity of devices in use must be included in the answer. This is needed to help confirm the scope and should be cross-referenced with the applicant regarding the number of sites and networks declared in A2.3 and A2.4. The answer to this question should be used to determine that the assessment has been correctly scoped and that the excluded networks have been properly segregated.
--	--	--	--	--



A2.5.1	If you are certifying as partial organisation, please list the equipment used to create any sub-sets.	Notes	Fail if blank	The applicant must list any routers, physical firewalls, or virtual firewalls (hosted on a hypervisor) that are being used to create sub-sets of their network. Note that software firewalls built into operating systems (for example Windows Firewall) cannot be used to define the boundary of the scope for this assessment. The answer to this question should be used to determine that the assessment has been correctly scoped and that the excluded networks have been properly segregated.
----------------------	--	--------------	-----------------------------	---



A2.6	Please list the quantities and operating systems for your laptops, desktops and virtual desktops within the scope of this assessment. Please Note: You must include make and operating system versions for all devices. All user devices declared within the scope of the certification only require the make and operating system to be listed. We have removed the requirement for you to list the model of the device. Only in-scope devices connecting to cloud services must be included in the assessment. Devices outside the declared scope are excluded, but user accounts accessing the cloud service must comply with Cyber Essentials controls, including mandatory MFA.	Notes	Fail if blank	The description must include all devices that contain or can access organisational data and services, including devices owned by employees (BYOD). If an unsupported OS is listed, then an auto-fail must be awarded. Guidance: Guidance to BYOD Operating System Support If using a VDI solution or hypervisors you must include end user devices and vice versa. The applicant must prove that all devices have a supported operating system. This does not need to include what individual update level they have installed. Windows 11 will need to include the version number and edition to determine the answer due to these going unsupported at various dates. For example, Windows 11 Professional 25H2. Mac OS may not need this level of detail and only require the OS name, for example Mac OS Tahoe. Linux may not need this level of detail and only require the OS name, for example Ubuntu 24.04 LTS, CentOS Stream 9. Build numbers are an acceptable alternative to providing versions on Microsoft operating systems.
-------------	--	-------	----------------------	---



	A scope that does not include end user devices is not acceptable.		You as the assessor must be confident that the details supplied in the answer prove that the scoped devices and software are still fully supported by the vendor. Pen testing machines running dedicated software, for example Kali Linux or Parrot OS are not compliant for Cyber Essentials and should be moved to a separate sub-set. Extended Security Update schemes For any end-of-life operating system that has an extended security update program, you must maintain the required subscription. Check with IASME if any such scheme is acceptable for compliance. If the applicant is using Windows 10 beyond the 14th October 2025 they must be signed up to the Microsoft Extended Security Update program in order to remain compliant and evidence for this must be provided. If you are marking through the IASME central pool, see Central Pool marking guidance above.
--	--	--	--



A2.6.1	Please list the quantity of thin clients within the scope of this assessment. Please include make and operating systems.	Notes	Fail if blank	The description must include all thin client devices that contain or can access organisational data and services. If an unsupported OS is listed, then an auto-fail must be awarded. Windows 10 and 11 will need to include the version number and edition to determine the answer due to these going unsupported at various dates. For example, Windows 10 IoT Enterprise 22H2. Other systems may not need this level of detail and only require the OS name. For example, iGel OS 11, HP Thin OS. If you are marking through the IASME central pool, see Central Pool marking guidance above. Cyber Essentials: Requirements for IT Infrastructure v3.3
---------------	--	-------	----------------------	---



A2.7	Please list the quantity of servers, virtual servers, virtual server hosts (hypervisors) and Virtual Desktop Infrastructure (VDI) servers. You must include the operating system.	Notes	Fail if blank	The description must include all devices that contain or can access organisational data and services. The applicant must provide a list of all server operating systems and any hypervisors that virtual servers run on. If an unsupported OS is listed, then an auto-fail must be awarded. The applicant must prove that all devices have a supported operating system, this does not need to include what individual update level they have installed. Windows Server will need to include the version number to determine the answer due to these going unsupported at various dates. For example, Windows Server Version 2022. Linux servers may not need this level of detail and only require the OS name. For example, RHEL 9. When hypervisors are listed, they must also be checked against the published EOL, if an unsupported hypervisor is listed then a auto-fail must be awarded. If you are marking through the IASME central pool, see Central Pool marking guidance above.
-------------	---	-------	----------------------	---



A2.8	Please list the quantities of tablets and mobile devices within the scope of this assessment. You must include make and operating system versions for all devices. Devices that are connecting to cloud services must be included. A scope that does not include end user devices is not acceptable.	Notes	Fail if blank	The description should include all equipment that contains or can access business data or services, including devices owned by employees (BYOD). If an unsupported OS is listed, then an auto-fail must be awarded. Guidance: Operating System Support Guidance to BYOD You should consider A6.4 when marking these questions. If mobile devices including tablets, smartphones, or mobile phones are not included in the list, you should query this with the client. Most businesses use at least one or two mobile phones for email. All tablets and mobile devices that connect to cloud services must be listed. This includes BYOD devices. You as the assessor must be confident that the details supplied in the answer prove that the operating systems of the scoped devices are fully supported by the vendor. The required level of detail includes the make and operating system to ensure the OS is supported and capable of receiving security updates. There is no obligation to declare the minor release details of the OS. However, if this information is provided and it is found that a newer version was released more than 14 days ago, it must be considered in
-------------	--	-------	----------------------	--



				section A6.4 of the assessment. As an assessor, you must not request this level of detail unless it is voluntarily provided by the applicant. It is not a requirement to list models. If you are marking through the IASME central pool, see Central Pool marking guidance above.
--	--	--	--	--



A2.9	Please list all of the cloud services that are in use by your organisation and provided by a third party. Please note that cloud services cannot be excluded from the scope of Cyber Essentials.	Notes	Fail if blank	You should expect to see a brief description of all cloud services that are provided by a third-party provider and used by the applicant here. This should include all IaaS, PaaS and SaaS services that are in use. Social media accounts (e.g. Facebook, LinkedIn, X) are also considered to be cloud services when used for business purposes, which follows many NCSC articles. If cloud services are not included in the list, you should query this with the client. Most businesses use at least one or two cloud services. If you notice cloud services mentioned elsewhere in the assessment that are not included here, you should challenge the applicant in this question. IaaS, PaaS and SaaS are defined in the Cyber Essentials Requirements for IT infrastructure document. Cyber Essentials: Requirements for IT Infrastructure v3.3 You as the assessor must be confident that the details supplied in the answer prove that the cloud services are still fully supported by the cloud provider. If you are marking through the IASME central pool, see Central Pool marking guidance above.
-------------	---	-------	----------------------	---



				2026 Update Definition of Cloud Service – A cloud service is an on-demand, scalable service, hosted on shared infrastructure, and accessible via the internet. For the purposes of Cyber Essentials, a cloud service will be accessed via an account (which may be credentials issued by your organisation, or an email address used for business purposes) and will store or process data for your organisation.
A2.10	Please provide the name and role of the person who is responsible for managing your information systems in the scope of this assessment.	Notes	Fail if blank	A named person and role must be provided. If the client doesn't want to provide the name for security reasons and they note this in their answer, they can provide it to you separately via a phone call. If you are marking through the IASME central pool, you must use the option of 'More information required' and state in the comments that they should provide this detail directly to IASME.



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 3: Insurance				
A3.1	Is your head office domiciled in the UK or Crown Dependencies and is your gross annual turnover less than £20m?	Yes/No	Fail if blank	This question relates to the insurance element of the assessment. Neither IASME or the assessor can make decisions or provide any views or advice on the insurance. It should be marked as compliant unless unanswered.
A3.2	If you have answered "yes" to the last question, then your organisation is eligible for the included cyber insurance if you gain certification. Would you like to opt in for the included cyber insurance?	Yes/No	Fail if blank	This question relates to the insurance element of the assessment. It should be marked as compliant unless unanswered. See Cyber Liability Insurance for details.
A3.3	What is the organisation email contact for the insurance documents? You only need to answer this question if you are taking the insurance.	Notes	Fail if blank	This question relates to the insurance element of the assessment. It should be marked as compliant unless unanswered.



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 4: Firewalls Questions in this section apply to: boundary firewalls, desktop computers, laptops, routers, servers, IaaS, PaaS, and SaaS. Further guidance can be found here: Knowledge Hub – Firewalls Firewalls – FAQ				
A4.1	Do you have firewalls at the boundaries between your organisation's internal networks, laptops, desktops, servers and the internet?	Yes/No	Non-compliance	The organisation must have firewalls at the boundary between internal networks and the internet. Where a whole organisation is made up completely of home workers their software firewalls would be considered their boundary unless connecting to a virtual firewall via corporate VPN. Award a non-compliance for a negative answer. Further guidance: Firewalls



A4.1.1	Do you have software firewalls enabled on all of your computers, laptops and servers?	Yes/No	Information only	Software firewalls should be enabled in addition to your internet boundary firewalls on a corporate network. Note – there is no requirement to have a software firewall on tablets or smartphones. This question is for information only and should always be marked as compliant if answered. Further guidance: About Firewalls
A4.1.2	If you answered no to question A4.1.1, is this because software firewalls are not installed by default as part of the operating system you are using? Please list the operating systems.	Notes	Non-compliance	The applicant should list the OS of their computers, laptops and servers that do not contain software firewalls. Software firewalls must be enabled unless they are not commonly available for the operating system being used. All versions of Windows and MacOS, and most common versions of Unix/Linux have software firewalls built-in to the operating system. A contradictory answer attracts a non-compliance.
A4.2	When you first receive an internet router or hardware firewall device, it may have had a default password on it. Have you changed all the default passwords on your boundary firewall devices?	Yes/No	Non-compliance	The default admin password must be changed on all routers and firewalls, including those that come with a unique password pre-configured (e.g. BT Business Hub, Draytek Vigor 2865ac) If a software firewall is being relied on as the network boundary, the applicant would need to understand that they need to change the default local admin password on the device. Award a non-compliance for a negative answer. Further guidance: About Routers



A4.2.1	Please describe the process for changing your firewall password. Home routers not supplied by your organisation are not included in this requirement.	Notes	Non-compliance	Applicants must be able to demonstrate they understand how to change their admin password on their firewalls and routers when they receive them to confirm they have changed their firewall passwords. If a third party is responsible for IT management, the applicant must detail how any third party manages password control and detail how they confirm with their provider how this requirement is met. If a software firewall is being relied on as the network boundary, the applicant would need to describe how their local admin password is configured. If the applicant does not understand the process award a non-compliance.
---------------	---	-------	-----------------------	--



A4.3	How is your firewall password configured? Please select the option being used: A. Multi-factor authentication, with a minimum password length 8 characters and no maximum length B. Automatic blocking of common passwords, with a minimum password length 8 characters and no maximum length C. A password minimum length of 12 characters and no maximum length D. Passwordless system is being used as an alternative to user name and password, please describe E. None of the above, please describe	Multiple Choice	Fail if blank	Firewall passwords must meet one of the following criteria: A. Multi-factor authentication, with a minimum password length of 8 characters and no maximum length B. Automatic blocking of common passwords, with a minimum password length of 8 characters and no maximum length C. A password with a minimum length of 12 characters and no maximum length D. Passwordless, please describe E. None of the above, please describe Award a non-compliance if Option E or Option D is non-compliant with passwordless definition. Further guidance: Bulletproof your passwords Cyber Essentials: Requirements for IT Infrastructure v3.3 Assessors, please note if using option D (passwordless) make sure that it follows the below definition. Passwordless authentication is an authentication method that uses a factor other than user knowledge to establish identity. Examples include but are not limited to: biometric data, physical devices, one-time codes, QR codes, and push notifications.
-------------	---	------------------------	-----------------------------	--



A4.4	Do you change your firewall password when you know or suspect it has been compromised?	Yes/No	Non-compliance	The organisation should take action to change passwords if it becomes aware that passwords may have been compromised. This applies to hardware firewalls and host devices where software firewalls are enabled. Further guidance: Compromised Accounts Award a non-compliance for a negative answer.
A4.5	Do you have a process to manage your firewall?	Yes/No	Non-compliance	This question also applies to applicants who are relying on their software firewalls to provide their boundary. Award a non-compliance for a negative answer.
A4.6	Have you reviewed your firewall rules in the last 12 months? Please describe your review process.	Notes	Non-compliance	When there is no longer a business need for a service, the firewall should be reconfigured to remove the service. Look for evidence of a process to disable unnecessary services or ports. Even if a service is enabled for the foreseeable future, there must be a process in place in the event that it is closed. This question also applies to applicants who rely on software firewalls. Award a non-compliance for a negative answer, or where no process is described.



A4.7	Is your firewall configured to allow unauthenticated inbound connections?	Yes/No	Non-compliance	By default, most firewalls block access to all services. This question focuses on the overall configuration of the firewall and seeks to ensure that the applicant's firewall is not set up to allow unauthenticated inbound connections by default. The goal is to confirm that the firewall is configured to block all inbound traffic unless explicitly permitted for specific, documented business purposes. It is acceptable for certain ports to be open if they are required for specific services and are supported by a valid business case (for example, HTTP ports). However, it is essential that these exceptions are carefully managed. All allowed services must undergo a documented review process. Award a non-compliance if the applicant answers 'Yes'. Consideration should also be given to the applicant's IaaS boundary. If the applicant has included IaaS in their scope and they answer 'No' then they would need to be challenged. If a contradictory answer is given, award a non-compliance.
A4.8	Please describe how you approve and document your allowed inbound connections.	Notes	Non-compliance	If services are enabled and advertised externally there must be a business case documented and recorded. Award a non-compliance where no process is described.



A4.9	Are your boundary firewalls configured to allow access to their configuration settings over the internet?	Yes/No	Fail if blank	This question is only concerned about allowing the firewall configuration interface to be accessible directly from the external interface of the firewall. If the interface is being accessed from inside the local network via a VPN connection, then this is compliant and a "no" answer to this question is acceptable The question is for information only and should always be marked as compliant if answered. Guidance on VPNs
A4.10	If you answered yes in question A4.9, is there a documented business requirement for this access?	Yes/No	Non-compliance	Award a non-compliance for a negative answer.
A4.11	If you answered yes in question A4.9, is the access to your firewall settings protected by either multi-factor authentication or by only allowing trusted IP addresses combined with managed authentication to access the settings?	Notes	Non-compliance	These are required and not optional if the firewall's admin interface is directly accessible via the internet. This requirement does not apply to accessing the configuration settings from inside the local network. If the method described does not confirm one of the compliant options, award a non-compliance.



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 5: Secure configuration Questions in this section apply to: servers, desktop computers, laptops, thin clients, tablets, mobile phones, IaaS, PaaS and SaaS. Further guidance: Knowledge Hub – Secure Configuration Secure configuration – FAQ				
A5.1	Have you removed or disabled software and services that you do not use on your laptops, desktop computers, thin clients, servers, tablets, mobile phones and cloud services? Describe how you achieve this.	Notes	Non-compliance	It is acceptable to use a "standard build" (where the organisation has decided which applications will be installed on all computers) to comply with this question. Some pre-installed applications on Android smartphones and tablets cannot be uninstalled – this is acceptable for this question. Further guidance: Removing unnecessary software



A5.2	Have you ensured that all your laptops, computers, servers, tablets, mobile devices and cloud services only contain necessary user accounts that are regularly used in the course of your business?	Yes/No	Non-compliance	Award a non-compliance for a negative answer.
A5.3	Have you changed the default password for all user and administrator accounts on all your desktop computers, laptops, thin clients, servers, tablets and mobile phones that follow the Password-based authentication requirements of Cyber Essentials?	Yes/No	Non-compliance	All user and admin accounts should have their default password changed - this includes smartphones and tablets. Details of the password requirements can be found in the Cyber Essentials Requirements for IT Infrastructure document. Award a non-compliance for a negative answer. Where applicants have not specifically stated whether they enforce complexity or have a maximum length, this can be addressed through an advisory, but it is not necessary to award a non-compliance.
A5.4	Do you run or host external services that provide access to data (that shouldn't be made public) to users across the internet?	Yes/No	Fail if blank	This could be a VPN server, a mail server, or an internally hosted internet application (SaaS or PaaS) that you provide to your customers as a product. In all cases, these applications provide information that is confidential to your business and your customers and that you would not want to be publicly accessible. This question is for information only and should always be marked as compliant if answered.



A5.5	If yes to question A5.4, which authentication option do you use? A. Multi-factor authentication, with a minimum password length of 8 characters and no maximum length B. Automatic blocking of common passwords, with a minimum password length of 8 characters and no maximum length C. A minimum password length of 12 characters and no maximum length D. Passwordless, please describe E. None of the above, please describe	Option A, B, C, D or E	Non-compliance	The password length must not be deliberately restricted to less than the natural limit of the operating system, server software or application in use. The applicant must choose all options that apply from the list. Award a non-compliance if Option E or no option is selected. If the applicant is using option D (passwordless) make sure that it follows the below definition. • Passwordless authentication is an authentication method that uses a factor other than user knowledge to establish identity. Examples include but are not limited to: biometric data, physical devices, one-time codes, QR codes, and push notifications. Cyber Essentials: Requirements for IT Infrastructure v3.3
-------------	--	-------------------------------	------------------------------	--



A5.6	Describe the process in place for changing passwords on your external services when you believe they have been compromised.	Notes	Non-compliance	The applicant should have a clear process in place in the event that their passwords are compromised. The applicant should detail what steps they take if they are notified or become aware of a security weakness from the vendor, or if they believe they have recently been a victim of having malware on their system. Where the applicant does not describe a clear process, a non-compliance should be awarded.
A5.7	When not using multi-factor authentication, which option are you using to protect your external service from brute force attacks? A. Throttling the rate of attempts B. Locking accounts after 10 unsuccessful attempts C. None of the above, please describe	Notes	Non-compliance	The applicant should describe the controls that they have in place to protect their services from being accessed from brute force attacks against their passwords. Compliant options are: • Using multi-factor authentication. • 'Throttling' the rate of attempts with no more than 10 guesses in 5 minutes. • Locking accounts after no more than 10 unsuccessful attempts. Where the applicant uses multi-factor authentication this needs to be confirmed within the answer. Award a non-compliance if no option is selected.



A5.8	Have you disabled any feature which allows automatic file execution of downloaded or imported files without user authorisation?	Yes/No	Non-compliance	It is acceptable to have a user prompt appear when a removable media is inserted, or when attempting to download from the internet where the user has to choose what action to take. Award a non-compliance for a negative answer.
A5.9	When a device requires a user to have the device in hand, do you set a locking mechanism on your devices to access the software and services installed?	Yes/No	Non-compliance	All devices must have a locking mechanism in place where the physical presence of a user is required to gain access. When a device requires the user's physical presence, it is essential to set a locking mechanism to access the software and services installed. This includes enabling biometric, password, or PIN locks to prevent unauthorised access to devices that handle organisational data or services. All devices must have such a locking mechanism to ensure that only authorised users can gain access. Award a non-compliance for a negative answer.



A5.10	Which method do you use to unlock the devices?	Notes	Non-compliance	The applicant must describe the method they use to unlock their devices. Acceptable methods of unlocking: • Biometric Test where credentials are used to solely access device. • Password or PIN of at least 6 characters where credentials are used to solely access device. The answer to this question should contain details of devices that require a physical presence to gain access. Where the unlocking credentials can be used elsewhere then the password-based authentication requirements as documented in User Access Controls must be met. These are: • MFA supported by an 8-character password • Minimum password length of 8 characters supported by a deny list • Passwords with a minimum length of 12 characters. These requirements will be confirmed in Section 7. Cyber Essentials: Requirements for IT Infrastructure v3.3 Where an applicant does not have any devices that require a physical presence to gain access, they must confirm this in their answer. If the applicant does not provide at least one compliant method of unlocking when devices are listed that require physical presence to unlock, award a non-compliance.
-------	--	-------	-----------------------	--



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 6: Security Update Management Questions in this section apply to: servers, desktop computers, laptops, tablets, thin clients, mobile phones, routers, firewalls, IaaS and PaaS cloud services. Further guidance: Knowledge Hub – Security Update Management Security Update Management – FAQ				



A6.1	Are all operating systems on your devices supported by a vendor that produces regular security updates and vulnerability fixes? If you have included firewall or router devices in your scope, the firmware of these devices is considered to be an operating system and needs to meet this requirement.	Yes/No	Auto-Fail	All operating system software must be receiving regular vulnerability fixes from the supplier. You as the assessor must be confident that the details supplied in the answer prove that the operating software is still fully supported by the vendor. Open-source operating systems are acceptable as long as updates are still being developed by the community. Software which has been forked and abandoned is not acceptable. Where a vendor or third party offers extended support for software this is compliant as long as there are details published that states the software is receiving regular vulnerability fixes and there is a published 'End of Life' (EOL) date for the support they are offering. Firmware for routers and firewalls must also be supported. Extended Security Update schemes For any end-of-life operating system that has an extended security update program, you must maintain the required subscription. Check with IASME if any such scheme is acceptable for compliance. If the applicant is using Windows 10 beyond the 14th of October 2025 they must be signed up to the Microsoft Extended Security Update program in order to remain compliant.
-------------	--	--------	------------------	--



				If insufficient details are listed, you can refer to the information provided in A2.5, A2.6, A2.6.1, A2.7, A2.8, and A2.9. If adequate information is detailed, then it is acceptable to pass as long as there are no contradictory answers elsewhere in the assessment. Award a fail overall for a non-compliant answer. Further guidance: Operating System Support Navigating the pitfalls of legacy software
A6.2	Is all the software on your devices supported by a supplier that produces regular vulnerability fixes for any security problems?	Yes/No	Non-compliance	All software must be receiving regular vulnerability fixes from the supplier. This includes things like office software, accounting software, internet browsers, plugins such as Flash, and utilities such as PDF readers. Open-source software is acceptable as long as fixes are still being developed by the community. Software which has been forked and abandoned is not acceptable. Award a non-compliance for a negative answer. This would also lead to a fail in A6.5 as the 14-day update rule is not being applied. When marking the answer to this question, reference should be made to A6.2.1/A6.2.2/AA6.2.3/A6.2.4. Versions should be provided for the applications listed. Any found to be unsupported must be awarded a non-compliance for A6.2, which would in turn lead to a fail in A6.5.



A6.2.1	Please list your internet browser(s). The version is required.	Notes	Fail if blank	Information only but unsupported applications will result in a non-compliance in A6.2. You as the assessor must be confident that the details supplied in the answer prove that the scoped applications and software are still fully supported by the vendor. If this is blank, a request for 'More Information' must be made.
A6.2.2	Please list your malware protection software. The version is required.	Notes	Fail if blank	Information only but unsupported applications will result in a non-compliance in A6.2. You as the assessor must be confident that the details supplied in the answer prove that the scoped applications and software are still fully supported by the vendor. If this is blank, a request for 'More Information' must be made.



A6.2.3	Please list your email applications installed on end user devices and servers. The version is required.	Notes	Fail if blank	Information only but unsupported applications will result in a non-compliance in A6.2. You as the assessor must be confident that the details supplied in the answer prove that the scoped applications and software are still fully supported by the vendor. If this is blank, a request for 'More Information' must be made.
A6.2.4	Please list all office applications that are used to create organisational data. The version is required.	Notes	Fail if blank	Information only but unsupported applications will result in a non-compliance in A6.2. You as the assessor must be confident that the details supplied in the answer prove that the scoped applications and software are still fully supported by the vendor. These applications should include all cloud services that offer authentication services such as MS365, Google Workspace. If this is blank, a request for 'More Information' must be made.



A6.3	Are any of the in-scope software or cloud services unlicensed or unsupported?	Yes/No	Non-compliance	Pirated software is not acceptable. As an assessor, you need to be aware that some operating systems, firmware, and applications require annual licensing to receive regular updates and vulnerability fixes. Examples to consider when marking this assessment include Citrix, VMWare, certain versions of Linux, and firmware in hardware firewalls. The assessor must confirm if any subscriptions/licences needed to receive updates are up to date with the applicant. The examples above are not an exhaustive list. Award a non-compliance if the applicant answers 'Yes'.
A6.3.1	If yes to A6.3, please list the unsupported or unlicensed software or cloud services.	Notes	Fail if blank	



A6.4	Are all high-risk or critical security updates and vulnerability fixes for operating systems and router and firewall firmware installed within 14 days of release?	Yes/No	Auto-fail	All software on in-scope devices must be updated, including vulnerability fixes, within 14 days of release, where: • The update fixes vulnerabilities described by the vendor as 'critical' or 'high-risk' • The update addresses vulnerabilities with a CVSSv3 base score of 7 or above • There are no details of the level of vulnerabilities the update fixes provided by the vendor There are no exceptions allowed to this rule. Other updates such as version and feature updates are not required to be installed as long as the software remains in support. If the applicant answers "No" to A6.4 this will result in failure of the assessment. If the applicant answers "No" to question A6.4.1 and provides no answer or a negative answer to A6.4.2, it will result in an automatic failure of A6.4. If a contradictory answer has been given elsewhere in the assessment that would suggest that high and critical updates were not being applied within 14 days, or for a negative answer, the assessment will fail.
A6.4.1	Are all updates applied for operating systems by enabling auto updates?	Yes/No	Fail if blank	Most devices have the option to enable auto updates. This must be enabled on any device where possible. If the question is unanswered award a fail.



A6.4.2	Where auto updates are not being used, how do you ensure all high-risk or critical security updates and vulnerability fixes of all operating systems and firmware on firewalls and routers are applied within 14 days of release?	Notes	Auto-fail	If the applicant has answered “No” to A6.4.1, the applicant must detail how they ensure that all high risk and critical updates and vulnerability fixes are applied within 14 days of release. The assessment will fail if the applicant does not explain how they apply all high and critical vulnerability fixes without auto updates, or if high and critical vulnerability fixes are not applied within 14 days of release. If auto updates are enabled and are the only method that an applicant uses to update their operating systems and firmware on firewalls and routers, they need to confirm this is the case in their answer. The assessor must also ensure that the solution allowing for manual updates is applicable to all operating systems included within the scope of the assessment.
---------------	---	-------	------------------	--



A6.5	Are all high-risk or critical security updates and vulnerability fixes for applications (including any associated files and extensions) installed within 14 days of release?	Yes/No	Auto-fail	All software on in-scope devices must be updated, including vulnerability fixes, within 14 days of release, where: • The update fixes vulnerabilities described by the vendor as 'critical' or 'high-risk' • The update addresses vulnerabilities with a CVSSv3 base score of 7 or above • There are no details of the level of vulnerabilities the update fixes provided by the vendor There are no exceptions allowed to this rule. If the applicant answers "No" to question A6.5 this will result in failure of the assessment. If the applicant answers "No" to question A6.5.1 and provides no answer or a negative answer to A6.5.2, it will result in an automatic failure of A6.5. Other updates such as version and feature updates are not required to be installed as long as the software remains in support. In the case of a negative answer, the assessment will be failed. Additionally, a non-compliance for A6.2 will also lead to a fail for this question.
A6.5.1	Are all updates applied on your applications by enabling auto updates?	Yes/No	Fail if blank	Most software has the option to enable auto updates. This must be enabled where possible. If the question is unanswered award a fail.



A6.5.2	Where auto updates are not being used, how do you ensure all high-risk or critical security updates of all applications are applied within 14 days of release?	Notes	Auto-fail	If the applicant has answered “No” to A6.5.1, the applicant must detail how they ensure that all high-risk and critical updates are applied within 14 days of release. You are looking for a brief explanation of how an applicant achieves this. Award a fail if the applicant fails to explain how they apply all high and critical vulnerability fixes without auto updates, or if high and critical vulnerability fixes are not applied within 14 days of release. If auto updates are enabled and are the only method that an applicant used to update their applications, they need to confirm this is the case in their answer.
A6.6	Have you removed any software installed on your devices that is no longer supported and no longer receives regular updates or vulnerability fixes for security problems?	Yes/No	Non-compliance	If unsupported applications are listed in A6.2.X then this would result in a non-compliance of A6.6 due to being a contradictory answer. Where the application is running as an unsupported version and can be upgraded to a supported version without removal then an advisory can be given in response to this question. Award a non-compliance for a negative answer.



A6.7	Where you have a business need to use unsupported software, have you moved the devices and software out of scope of this assessment? Please explain how you achieve this.	Notes	Non-compliance	The applicant should demonstrate they understand that they need to remove unsupported software by network segregation based on the definition of a sub-set. Where the applicant has shown that unsupported software has been moved to a sub-set then the assessor should check that a clear scope description has been given in A2.2. Where unsupported software is in use on a scoped network and not moved to a defined sub-set, award a non-compliance. Further guidance: Subset Scoping Guidance
-------------	---	-------	-----------------------	--



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 7: User Access Control Questions in this section apply to: servers, desktop computers, laptops, tablets, thin clients, mobile phones, IaaS, PaaS and SaaS Further guidance : Knowledge Hub – User Access Control User Access Control – FAQ				
A7.1	Are your users only provided with user accounts after a process has been followed to approve their creation? Describe the process.	Notes	Non-compliance	The applicant should be able to describe the process including who approves creation of accounts. Award a non-compliance where no process is described.
A7.2	Are all your user and administrative accounts accessed by entering unique credentials?	Yes/No	Non-compliance	User and administrator accounts must not be shared and must be unique to the user. There must be no shared accounts or accounts that are left logged in permanently. Award a non-compliance for a negative answer.



A7.3	How do you ensure you have deleted, or disabled, any accounts for staff who are no longer with your organisation?	Notes	Non-compliance	The applicant should be able to describe a clear process. Award a non-compliance where no process is described.
A7.4	Do you ensure that staff only have the access privileges that they need to do their current job? How do you do this?	Notes	Non-compliance	When a staff member changes roles, their access permissions should be updated to match their new responsibilities. This involves a process to review and adjust their access to files, folders, and applications. The question focuses on general user access, not just admin privileges. For Cyber Essentials it is required that the principle of least privilege is applied. If the applicant's response shows a lack of understanding, more information should be requested. Award a non-compliance where no process is described, or the process does not meet the guidance above.
A7.5	Do you have a formal process for giving someone access to systems at an "administrator" level and can you describe this process?	Notes	Non-compliance	The applicant notes must demonstrate that a process is in place for formal approval of administrator access. Award a non-compliance where no process is in place.



A7.6	How does your organisation make sure that separate accounts are used to carry out administrative tasks (such as installing software or making configuration changes)?	Notes	Non-compliance	You as an assessor must be confident that the applicant is providing enough detail to demonstrate they are applying account separation and not privilege elevation. You should ensure that the statements provided about admin access also apply to cloud service administrator accounts. Separate administrator/admin accounts for all IaaS and other cloud services that offer authentication as a service (for example Microsoft 365 and Google Workspace) are required. In addition to account separation, the applicant should demonstrate measures to prevent misuse of administrator accounts including internal users and third-party accounts such as MSPs, IT service companies, etc. Award a non-compliance for an answer that does not demonstrate separation of user and administrator accounts. Further guidance: User Access - Just Enough or Just In Time
A7.7	How does your organisation prevent administrator accounts from being used to carry out everyday tasks like browsing the web or accessing email?	Notes	Non-compliance	Admin accounts must not be used for day-to-day work, even if the user is a technical user that needs to make regular changes to systems. This can be a combination of policy, process and training. The technical control here would be the use of the separate accounts and for this question additional technical measures are not required. The question is specifically asking how the applicant ensures that those with administrator accounts (including third parties such as MSPs) do not use their admin accounts for everyday tasks.



				Separate administrator / admin accounts for all IaaS and other cloud services that offer authentication as a service (for example Microsoft 365 and Google Workspace) are required. Award a non-compliance where there is no policy, process or training described.
A7.8	Do you formally track which users have administrator accounts in your organisation?	Yes/No	Non-compliance	This must be tracked formally and would be a result of the process described in A7.5. Award a non-compliance for a negative answer.
A7.9	Do you review who should have administrative access on a regular basis?	Yes/No	Non-compliance	The organisation must regularly review the list of admin users to ensure that only those who actually need administrator access are provided with it. For this assessment we do not define what constitutes as regular. The applicant needs to answer 'Yes' and as long as they do not contradict their answer in the applicant notes, this answer can be marked as compliant. Award a non-compliance for a negative answer.
A7.10	Where you have systems that require passwords (or where passwords are a backup for a passwordless system), how are they protected from brute-force attacks?	Notes	Non-compliance	The applicant must describe how they protect their accounts from brute-force password attacks within their organisation. The acceptable methods of brute force protection are: • Using multi-factor authentication • 'Throttling' the rate of attempts, permitting no more than 10 guesses in 5 minutes. • Locking accounts after no more than 10 unsuccessful attempts Cyber Essentials Requirements for Infrastructure v3.3 If one of the methods listed above are not described within the answer then a non-compliance is to be awarded.



A7.11	Which technical controls are used to manage the quality of your passwords within your organisation?	Notes	Non-compliance	The applicant must describe what technical controls they have in place to manage the quality of their passwords within their organisation. Within their answer they must list one of the following controls: • Using multi-factor authentication • A minimum password length of at least 12 characters, with no maximum length restrictions • A minimum password length of at least 8 characters, with no maximum length restrictions and use automatic blocking of common passwords using a deny list Cyber Essentials Requirements for Infrastructure v3.3 If none of the methods above are listed award a non-compliance.
A7.12	Please explain how you encourage people to use unique and strong passwords.	Notes	Non-compliance	The applicant must describe how they encourage people to pick unique and strong passwords. The Requirements for IT Infrastructure document gives applicants the following ways they can support staff: • Education on how to avoid common or discoverable passwords • Encouraging longer passwords by using multiple words (e.g. 'Three Random Words') • Providing advice on password storage • Not enforcing regular password expiry • Not enforcing complexity requirements Cyber Essentials Requirements for Infrastructure v3.3 If the applicant does not understand the question or does not encourage people to use unique and strong passwords award a non-compliance. Applicants are not required to demonstrate every point listed above.



A7.13	Do you have a process for when you believe the passwords or accounts have been compromised?	Yes/No	Non-compliance	The applicant must have an established process to include the prompt changing of passwords that should be carried out in the event that they suspect passwords and/or accounts have been compromised. Award a non-compliance for a negative answer. Further guidance : Compromised accounts
A7.14	Do all of your cloud services have multi-factor authentication (MFA) available as part of the service? A cloud service is an on-demand, scalable service, hosted on shared infrastructure, and accessible via the internet. For the purposes of Cyber Essentials, a cloud service will be accessed via an account (which may be credentials issued by your organisation, or an email address used for business purposes) and will store or process data for your organisation.	Yes/No	Information only	Authentication to cloud services must always use MFA. Where a cloud service does not have its own MFA solution, if it can be configured to authenticate using another cloud service that does provide MFA this is acceptable. This question is now information-only. If the applicant answers “No” then they must answer question A7.15. Further guidance: Applying MFA to access cloud services Securing Your Cloud Services



A7.15	If you have answered 'No' to question A7.14, please provide a list of your cloud services that do not provide any option for MFA.	Notes	Auto-fail if MFA is available on a listed service	The applicant should list their cloud services that do not provide MFA. Information may be reported back to the NCSC. Cloud Services MFA The assessor must check whether any cloud services listed here have MFA. If an applicant lists a cloud service that has MFA available this will result in an auto fail of the assessment. Check information given here with the answer to A2.9 (Cloud Services) to ensure that the assessment has been scoped correctly.
A7.16	Has MFA been applied to all administrators of your cloud services, excluding any listed in A7.15 that do not provide it?	Yes/No	Auto-fail	MFA must be applied to all administrator accounts on cloud services. When A7.14 has been answered 'No' then A7.15 needs to be answered and cloud services checked for MFA. If any that are listed are found to have MFA available this will result in an auto fail of the assessment. If the applicant decides to not apply MFA to admin accounts when it is available, this will result in automatic failure of the assessment. If the applicant answers "No" to this question the assessment will fail.



A7.17	Has MFA been applied to all users of your cloud services, excluding any listed in A7.15 that do not provide it?	Yes/No	Auto-fail	MFA must be applied to all user accounts on cloud services. When A7.14 has been answered 'No' then A7.15 needs to be answered and cloud services checked for MFA. If any that are listed are found to have MFA available this will result in an auto fail of the assessment. If the applicant decides to not apply MFA to user accounts when it is available, this will result in automatic failure of the assessment. If the applicant answers "No" to this question the assessment will fail.
--------------	---	--------	------------------	---



Question Ref	Question	Answer Type	Mark to be awarded	Notes on Marking
Section 8: Malware Protection Questions in this section apply to: servers, computers, laptops, tablets, thin clients, mobile phones, IaaS, PaaS and SaaS Further guidance: Knowledge Hub – Malware Protection Malware Protection – FAQ				
A8.1	Are all of your desktop computers, laptops, tablets and mobile phones protected from malware by either: A – Having anti-malware software installed and/or	Multiple choice	Non-compliance	Each device must be protected from malware by using one of the two techniques (A or B). Look for evidence across the following questions that all devices are covered by at least one of the techniques. Anti-malware software is an acceptable option for servers, desktop computers and laptops running Windows or MacOS. All devices can use application allow listing as an option.



	B - Limiting installation of applications by application allow listing - for example, using an app store and a list of approved applications, using a Mobile Device Management (MDM) solution or C - None of the above, please describe			Only selecting 'B' is acceptable, however, where a device has not been considered within this answer (for example only ticking 'A' and having mobile devices in scope) award a non-compliance. If option C has been selected a description is required. If only option C has been selected award a non-compliance.
A8.2	If Option A has been selected: Where you have anti-malware software installed, is it set to update in line with the vendors guidelines and prevent malware from running on detection?	Yes/No	Non-compliance	Anti-malware software is an acceptable selection for all servers, desktop computers and laptops that run Windows or Mac OS. All anti-malware software should be updated in line with the vendors guidelines. When anti-malware software is used, it must prevent malware from running on detection. Award a non-compliance for a negative answer.



A8.3	If Option A has been selected: Where you have anti-malware software installed, is it set to scan web pages you visit and warn you about accessing malicious websites?	Yes/No	Non-compliance	The anti-malware software must prevent users from accessing malicious websites, either through a regularly updated list of suspect sites or more sophisticated methods. Award a non-compliance for a negative answer.
A8.4	If Option B has been selected: Where you use an app-store or application signing, are users restricted from installing unsigned applications?	Yes/No	Non-compliance	Application allow listing is an acceptable selection for all devices. When using application allow listing only approved applications, restricted by code signing, are allowed to execute on devices. Award a non-compliance for a negative answer.
A8.5	If Option B has been selected: Where you use an app-store or application signing, do you ensure that users only install applications that have been approved by your organisation and do you document this list of approved applications?	Yes/No	Non-compliance	Users should only be able to install applications that have been approved by the organization. The list of approved applications should be made available to all users and reviewed on a regular basis. For BYOD, this list only reflects the applications that should be used to interact with organisational services and/or organisational data. Approval is not required for personal applications unless they are used on a corporate owned device. Award a non-compliance for a negative answer.